CS 6338 KNOWLEDGE ENGINEERING • TERM PROJECT PROPOSAL (MILESTONE 1)

# Intelligent GraphRAG Chatbot for Cyber Threat Reports

Team **CTRL ALT DEFEAT** • Shane Waldrop (swaldrop2@angelo.edu)
Angelo State University • Instructor: Dr. Erdogan Dogdu • October 2026

**Summary.** The system answers a threat analyst's multi-hop questions about cyber threat reports, meaning questions whose answers join several linked facts. It is a GraphRAG system (graph retrieval-augmented generation): a Neo4j knowledge graph joins the AnnoCTR reports with MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) version 20.0, the structured catalogue of adversary behaviour. A large language model (LLM) extracts from each report the ATT&CK techniques, tactics, groups and software it names or describes. Answers come from retrieved report text plus the graph around the entities in it; the model is told to cite the report chunk or graph relationship behind every statement, and code checks that each cited ID was in its context. **Status on 19 October 2026:** the pipeline runs end to end on one development report, and the benchmark (682 gold triples, 24 multi-hop questions) is built and verified.

## 1 Team & Role Distribution

Team name: **CTRL ALT DEFEAT**. Member: Shane Waldrop, swaldrop2@angelo.edu. The course specifies teams of two to three students; this team has one member, who holds every role in Table 1, so the secondary column reads "none". The checks a second member would provide are automated instead: 86 automated tests, a recomputation of every benchmark answer by Cypher (Neo4j's query language) inside Neo4j, and an independent reimplementation of the benchmark (Section 3).

**Table 1:** Component ownership matrix (UI: user interface).

| Role | Responsibilities in this project | Primary | Secondary |
|---|---|---|---|
| Data & Annotation Lead | AnnoCTR and ATT&CK data audit; gold triples; question set; verification | S. Waldrop | none |
| Graph Extraction & Reasoning Lead | extraction prompt, checks; linking to ATT&CK; RDF/OWL ontology (Resource Description Framework / Web Ontology Language); fusion, inference rule; GDS (Neo4j Graph Data Science) analytics | S. Waldrop | none |
| Embedding & Retrieval Lead | chunk and graph embeddings; vector indexes; personalized-PageRank retrieval | S. Waldrop | none |
| Evaluation & UI Lead | scorer; RAGAS (Retrieval-Augmented Generation Assessment) metrics; blind rating sheet and rating; Streamlit chat page | S. Waldrop | none |

## 2 Problem Statement & Domain Context

**Domain.** Cyber threat intelligence (CTI). Security vendors publish threat reports in prose; analysts translate them into MITRE ATT&CK [2], the public catalogue of adversary behaviour (v20.0, released 13 October 2026: 15 tactics, 706 techniques of which 479 are sub-techniques, 178 groups, 842 software, 44 mitigations), to decide which detections and mitigations matter.

**Why text-only RAG struggles here.** Retrieval-augmented generation (RAG) hands the $k$ report chunks most similar to the question to a language model [3]. It struggles with four kinds of question analysts ask:

(1) *The answer is not in the report.* Mitigations, a group's known software and a technique's tactics are ATT&CK facts that reports rarely state. Measured on the *tracer report*, a development (dev) report run end to end as the first test (Lab52, June 2020, Mustang Panda): asked which ATT&CK mitigations address the report's techniques, the text-only baseline replied that its context names no mitigations, while the graph-enriched pipeline named four (M1038, M1047, M1017, M1031) with 10 citations, each pointing to a fact in its context. The four follow the system's own links, which missed five of the eight expert-labelled techniques, among them T1036 and T1055; M1022 and M1040, which address the most expert-labelled techniques, are absent. Section 6 measures answer quality.

(2) *Behaviour is described, not named.* Of the 1,526 expert links to ATT&CK in the test reports, 691 (45%) are implicit (in a dev report, "with a legitimate binary" is linked to T1036 Masquerading), and only 288 mention texts (19%) equal an ATT&CK name or alias, compared ignoring case.

(3) *Questions chain and aggregate facts.* "Which mitigation addresses the most techniques in report $R$?" needs every technique of $R$, every MITIGATES relationship into those techniques (27 to 192 for the five such benchmark questions) and a count. Similarity search over chunks supplies none of those joins; the graph supplies them, and the planned engine computes the counts in Cypher before the model answers (Section 5(d)).

(4) *The catalogue moves.* Recent ATT&CK releases renamed the tactic Defense Evasion to Stealth, added Defense Impairment and revoked T1562 in favour of T1685. A model's memory of older releases gives outdated names; a graph loaded from

v20.0 carries the current ones.

**Persona.** A security operations center (SOC) or CTI analyst who reads vendor reports, must prioritise defences, and needs each claim traceable to the report sentence or ATT&CK relationship behind it. **Questions the chatbot answers.** Ten multi-hop patterns (Table 2); each benchmark question names its report $R$ by vendor, month and title.

**Table 2:** The ten question patterns, with the number of benchmark questions ($n$) of each.

| Pattern | $n$ | Pattern | $n$ |
|---|---|---|---|
| Mitigations that address the most of $R$'s techniques | 5 | $R$'s techniques that ATT&CK records group $G$ as using | 2 |
| Tactics under which ATT&CK places $R$'s techniques | 4 | Group in $R$ that uses the most of $R$'s techniques | 1 |
| Software in $R$ that the group in $R$ uses | 2 | $R$'s techniques that ATT&CK records software $S$ as using | 3 |
| Groups in $R$ that use the software in $R$ | 1 | $R$'s techniques missing from ATT&CK's record of $S$ | 1 |
| Groups that use every technique of $R$ | 2 | Techniques that reports $R_1$ and $R_2$ both describe | 3 |

## 3 Dataset & Ground-Truth Verification Plan

**Text corpus.** AnnoCTR [1]: the 120 English threat reports (2016–2022) that carry AnnoCTR's cybersecurity annotation layer, donated by Intel 471, Lab52 (S2 Grupo), Proofpoint, QuoIntelligence and Zscaler; 1.20 million characters (152,887 words) after embedded images are removed; split by its authors into 70 train, 16 dev and 34 test reports; licence CC BY-SA 4.0 (source commit `d510b69`). **Structured source.** MITRE ATT&CK v20.0 Enterprise, a STIX (Structured Threat Information Expression) 2.0 JSON (JavaScript Object Notation) bundle of 49 MB: 1,785 live entries and 19,545 relationship objects are used, plus 881 technique-to-tactic links read from the techniques' kill-chain phases (20,426 relationships in all).

**Existing annotations.** Domain experts marked mentions of techniques, tactics, groups and software and linked them to ATT&CK: 5,626 links (train 3,326, dev 774, test 1,526). AnnoCTR has no expert labels for relations between entities, so the "uses" relations the model extracts cannot be scored against expert labels.

**Gold triples (minimum 50; built 682).** One triple (report, `MENTIONS`, ATT&CK entry) for every entry the experts linked in all 16 dev and 34 test reports; in the graph, a triple stands for the path Report → HAS_CHUNK → Chunk → MENTIONS → entry. The triples cover those reports completely, not a sample, so precision is measurable against the experts' labels, though a correct link they did not make counts as an error (the tracer report has one, APT27 → G0027), and a second annotator's technique sets agree with the first at only 54% average F1 (the harmonic mean of precision and recall) [1]. Expert IDs are mapped to v20.0: 10 report-level links to the revoked T1562 become T1685, and 6 report-level links (10 mentions) to ATT&CK Mobile IDs, absent from the Enterprise domain, are set aside. Test: 469 triples (327 techniques, 85 tactics, 13 groups, 44 software); dev: 213. Every technique label names a parent technique, never a sub-technique.

**Multi-hop question–answer (QA) pairs (minimum 20; built 24).** Pairs in ten patterns over 20 of the 34 test reports, chosen from the gold facts and never from system output, with answers of 1 to 6 items. Each answer is computed from the gold triples and ATT&CK, never from the system's own graph, and each question stores a reference answer in words, its supporting facts and a Cypher query. Because the experts label parent techniques, a relationship that ATT&CK records for a sub-technique counts for its parent.

**Verification.** (i) Both files are written by a committed script, `gold.py`; a test rebuilds them and fails on any difference. (ii) Each question's Cypher query recomputes its answer inside Neo4j: 24 of 24 agree (measured 19 October). (iii) A separate reimplementation from the raw files reproduced all 24 answers and the test gold totals. (iv) Three answers were compared item by item with attack.mitre.org pages, read through an automated page reader. **Split discipline.** Train reports supply the prompt's two worked examples only; dev reports are for trying changes and calibrating the linking threshold; the test reports run once, for the reported numbers.

## 4 Target Knowledge Graph Schema & Ontology

**Node types.** Report; Chunk (a 4,000-character window); the five ATT&CK classes Technique (including sub-techniques), Tactic, Group, Software and Mitigation; Entity (a name the linker could not tie to ATT&CK). **Relationship types.** `HAS_CHUNK`; `MENTIONS` (chunk to the entry it names or describes); `USES` (from ATT&CK: group to technique, software to technique, group to software; from text, between whatever entries or Entity nodes the two mentions link to); `SUBTECHNIQUE_OF`; `PART_OF_TACTIC`; `MITIGATES`. **Key attributes.** Every relationship carries `edge_id` (the ID that answers cite) and `source` (`attack` or `text`). `MENTIONS` adds `report_id`, `chunk_id`, the mention text, the verbatim evidence sentence, `link_method`, `confidence` (1.0 for an exact name match, the cosine similarity for an embedding match), the model's own confidence (stored; the dev calibration tests a cut-off on it), the model name and the extraction timestamp. One uniqueness constraint per node label guards every key.

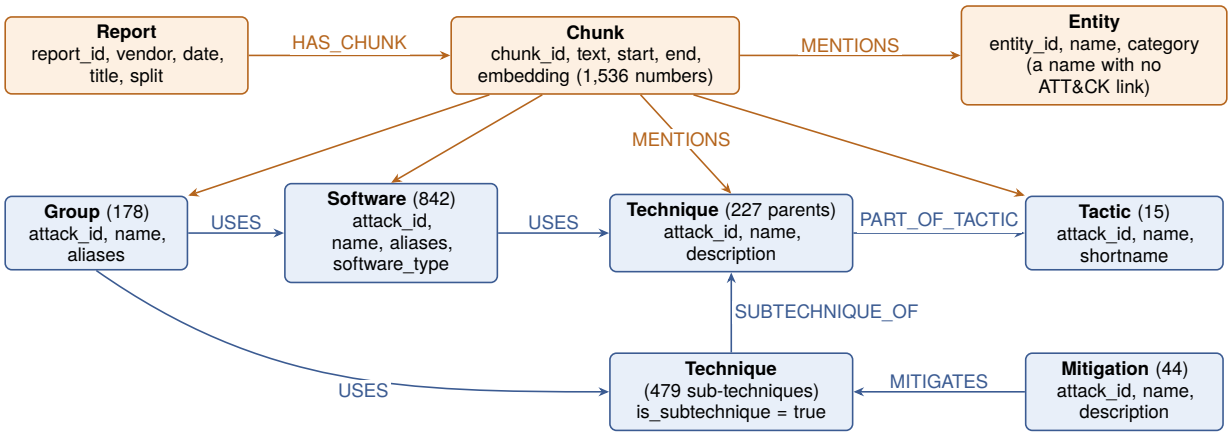



**Figure 1:** Knowledge-graph schema. Orange: nodes and relationships from reports (`source = "text"`); blue: MITRE ATT&CK v20.0 (`source = "attack"`) with live entry counts. Sub-techniques are Technique nodes. MENTIONS reaches any ATT&CK node, sub-techniques and mitigations included, or an Entity; USES and MITIGATES reach techniques and sub-techniques alike.

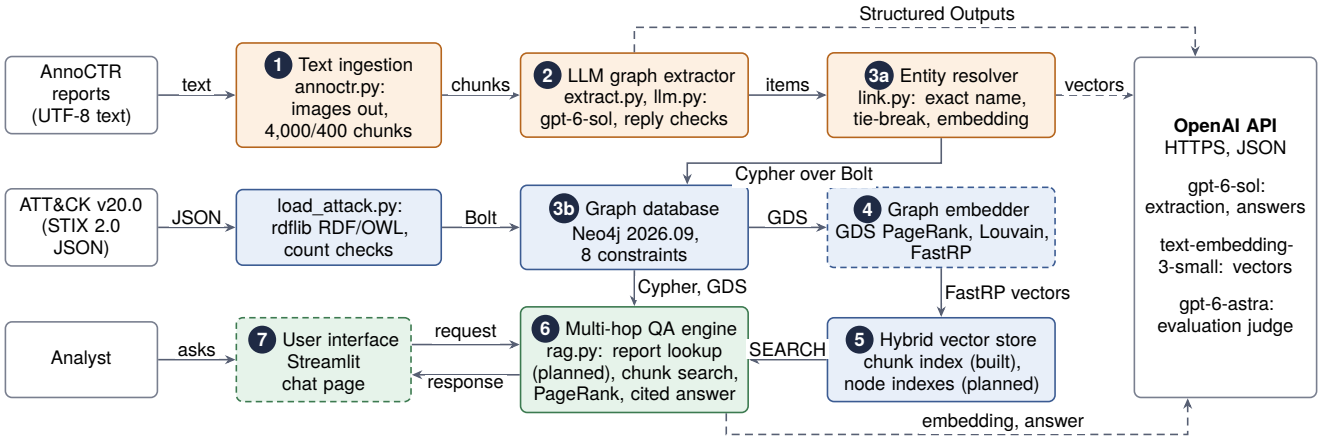



**Figure 2:** Architecture: the seven subsystems of the design (1 text ingestion, 2 LLM graph extractor, 3a entity resolver and 3b graph database, 4 graph embedder, 5 hybrid vector store, 6 multi-hop question-answering (QA) engine, 7 user interface). Dashed outline: not built yet. Dashed arrow: an HTTPS (encrypted web) call to the OpenAI application programming interface (API). Neo4j holds the graph and every vector index. FastRP: fast random projection.

**Ontology.** ATT&CK enters as RDF/OWL built with rdflib: OWL classes for the five ATT&CK kinds and object properties `uses`, `mitigates`, `subtechniqueOf` and `partOfTactic` (194,611 triples). RDF 1.1 cannot attach properties to a triple, so each relationship is also an `rdf:Statement` carrying its `edgeId`, `source` and description; Neo4j's labeled property graph (LPG) stores the same properties on the relationship itself.

## 5 Proposed GraphRAG System Architecture

**(a) LLM extraction.** gpt-6-sol (OpenAI) at reasoning effort *none*, temperature 0 and seed 7, at most 4,000 output tokens per call. Replies are forced into a JSON schema generated from Pydantic models: mentions (id, text, category, ATT&CK name, evidence sentence, confidence) and "uses" relations between mention ids. Two worked examples from train reports precede each chunk. Chunks hold 4,000 characters with a 400-character overlap (dev 50, test 99 chunks). Code, not the model, assigns every permanent ID and checks each item against the chunk text; 13 reasons for dropping output are counted separately (tracer report, 19 October, earlier one-example prompt, the run behind every tracer figure here: 29 mentions and 9 relations kept, none dropped). Every reply is saved under a hash of its request, so reruns are identical and free. A local model (qwen3:4b, run with Ollama) will be shown on one chunk.

**(b) Graph enhancement & verification.** *Entity resolution* (named entity disambiguation) links each mention to ATT&CK: exact match of the model's ATT&CK name, then of the mention text, against 2,927 keys (2,448 distinct names and aliases, compared ignoring case and punctuation, plus 479 "Parent: Sub-technique" names) across all five ATT&CK kinds; written tie-break rules for the 49 keys shared by several entries; otherwise embedding similarity (text-embedding-3-small over each

entry's name and description) above a threshold to be calibrated on the 213 dev facts (provisionally cosine 0.40); otherwise an Entity node keyed by category and normalised name, so repeated unlinked names merge (measured on the tracer report: 23 exact and 6 embedding links). *Reasoning* has two layers: data fusion of ATT&CK, the external structured source, with the extracted report facts; and an inference rule, applied in every benchmark query, that a relationship ATT&CK records for a sub-technique also holds for its parent technique. GDS adds PageRank, Louvain communities [8] and FastRP (fast random projection) embeddings in the full build (Phase 5), for the final report's analysis and the chat page's "similar entries"; they stay out of the answer prompt, because a similarity score is not a citable fact. *Verification*: `score.py` compares the system's facts with the gold triples (Section 6).

**(c) Embedding & indexing.** Chunk embeddings come from text-embedding-3-small (1,536 numbers) in a Neo4j vector index: HNSW (hierarchical navigable small world) [9], cosine similarity, no quantization. Graph embeddings will come from FastRP [7]: 128 dimensions, fixed random seed, one thread, over the ATT&CK graph, stored in vector indexes for Technique, Group and Software. Louvain community IDs and PageRank scores will become node properties. Analytics outputs will be saved to files and reloaded, so every machine uses the same values. Neo4j serves as both graph store and vector store.

**(d) Retrieval & generation.** The engine will first look up (planned) the report a question names, matching a quoted title against the Report nodes' titles, and takes the 4 chunks most similar to the question (planned: from that report when one is found). The entities those chunks mention (planned: and every entity the named report mentions), ATT&CK entries and Entity nodes alike, seed a personalized PageRank [6] over ATT&CK's relationships and the "uses" relations found in text, the retrieval idea of HippoRAG [5]; Microsoft's GraphRAG [4] instead summarises communities of an LLM-built graph for corpus-wide questions. Among the 200 best-scoring nodes, summary lines (planned) state for each nearby ATT&CK entry how many of the report's entities it links to, with an edge ID per link, so a counting question gets counts computed in Cypher. Then come up to 40 mention facts and at most 60 relationship facts (seed to seed first, then one step out, then two, taken in turn from each type). The prompt template tells the model to use only that context and to cite after every statement, as `[chunk:ID]` or `[edge:ID]`; code then checks that every cited ID was in the context. A Streamlit page will show the answer, its citations, and the chunks and facts used.

## 6 Evaluation & Benchmarking Strategy

**Automated metrics.**

- *Entity extraction and linking:* precision, recall and F1 of (report, ATT&CK entry) facts against the 469 test gold triples, overall and per kind, at sub-technique and parent level, with a scorer tested on five hand-made cases. Reported beside a baseline that links every ATT&CK name or alias found verbatim (ignoring case) in a report's text, and, for context, the AnnoCTR paper's best document-level F1 (techniques 56.6, tactics 47.7, sub-techniques collapsed to parents). Measured on the tracer report: F1 0.519 at sub-technique level, 0.593 at parent level.
- *Answer accuracy:* per question, precision, recall and F1 of the IDs of the kind the question asks for, named in the answer outside its citations, against the answer IDs stored with each question, averaged over the 24 questions.
- *RAGAS* [10]: faithfulness, answer relevance and context recall, judged by gpt-6-astra. Language-model judges can favour text that resembles their own output [11,12,13], and the answer model and the judge are both OpenAI GPT-6 models, so RAGAS scores are reported as a judge's estimate, with one judge for both systems, beside the human ratings.
- *Operations:* citation-ID validity rate, latency per stage, cost per question.

**Human testing.** Both systems answer all 24 questions. Before rating, a script replaces each citation with a neutral number and lists the cited texts in one format for both systems (raw citations would reveal the system, since only GraphRAG cites graph facts), then shuffles each question's two answers with a fixed seed and labels them A and B. The rater scores the 48 answers from 1 to 5 on Factuality, Completeness and Coherence against the anchors in Table 3 and the reference answers. The rater is the member who built the system, and the kind of evidence cited can still hint at the system; the ID-based answer accuracy needs no rater. **Baseline.** The same pipeline with the graph switched off: same question embedding, same 4 chunks, same model and citation rules, no graph facts.

## 7 Technical Risk Analysis & Mitigation Plan

Table 4 lists the six main technical risks, each with its mitigation and the evidence so far.

## 8 Project Timeline & Phase-Wise Milestones

Table 5 follows the course's milestone plan; S. Waldrop leads every milestone. Remaining work, estimated in hours of the member's time: full build 2–4, evaluation 2–3, report and slides 1–2, video and submission 1–2.

**Table 3:** Human rating anchors (2 and 4 lie between the neighbouring anchors). Completeness follows the share of the reference answer's items given, so a one-item answer scores 5 or 1.

| Score | Factuality | Completeness | Coherence |
|---|---|---|---|
| 5 | every statement correct and supported by its citation | every item of the reference answer | direct, well organised, no repetition |
| 3 | mostly correct; one material error | at least half of the items | understandable, some disorder |
| 1 | mostly wrong or unsupported | none of the items | incoherent or off the question |

**Table 4:** Main technical risks.

| Risk | Mitigation (and evidence so far) |
|---|---|
| API cost and rate limits | Every reply saved and reused: the tracer run cost about $0.07 (measured tokens at list prices); all 149 dev and test chunks, about $3.8, and the RAGAS judge, roughly $30–45 (both estimated). The OpenAI client retries a rate-limited call up to 3 times with backoff. |
| Extraction noise and malformed output | Schema-enforced replies; verbatim text and evidence checks; 13 drop reasons counted separately; changes tried on dev only. |
| Entity disambiguation | 45% of mentions are implicit and 49 keys are shared: the model writes ATT&CK names; exact-then-embedding linking across all kinds; written tie-breaks; threshold and a confidence cut-off to be calibrated on dev. |
| Refusals or content filtering of malware text | Counters for refusals, filtered and cut-off replies; each reply saved; an affected chunk's labels count as missed, so the scores show the loss. |
| Judge bias and a single rater | Neutral citation numbers and shuffled, unlabelled answers; written anchors; answer accuracy computed from IDs needs no judge or rater. |
| Results differing across machines | 120 pinned packages; saved replies; GDS with one thread and (planned) fixed seeds and analytics saved to files (measured: benchmark files rebuild byte-identically on Windows and Linux). |

**Table 5:** Week-by-week plan against the course milestones (KG: knowledge graph), with status on 19 October 2026.

| Week | Milestone | Work in this project | Status |
|---|---|---|---|
| 3–4 | Preparation | data audit (AnnoCTR, ATT&CK v20.0); repository; pinned environment; Neo4j with APOC (Awesome Procedures On Cypher) and GDS | done |
| 5 | M1 Proposal & dataset | schema applied; ATT&CK loaded and counted; 682 gold triples; 24 QA pairs | done except submission |
| 6 | M2 Extraction & KG store | one dev report end to end; next: all 16 dev reports, then the 34 test reports once | in progress |
| 6 | M3 Reasoning & embeddings | linker built; next: calibration on dev, GDS analytics, node indexes | in progress |
| 7 | M4 Hybrid retrieval engine | personalized-PageRank retrieval built; next: report lookup, summary lines, chat page | in progress |
| 8 | M5 Evaluation & final | scorer built; RAGAS and blind ratings; final report, slides, video | planned |

## References


[1] L. Lange, M. Müller, G. Haratinezhad Torbati, D. Milchevski, P. Grau, S. C. Pujari, A. Friedrich. AnnoCTR: A Dataset for Detecting and Linking Entities, Tactics, and Techniques in Cyber Threat Reports. LREC-COLING 2024, pp. 1147–1160.

[2] B. Strom, A. Applebaum, D. Miller, K. Nickels, A. Pennington, C. Thomas. MITRE ATT&CK: Design and Philosophy. MITRE, 2020.

[3] P. Lewis et al. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks. NeurIPS 33, 2020, pp. 9459–9474.

[4] D. Edge et al. From Local to Global: A Graph RAG Approach to Query-Focused Summarization. arXiv:2404.16130, 2024.

[5] B. Jiménez Gutiérrez, Y. Shu, Y. Gu, M. Yasunaga, Y. Su. HippoRAG: Neurobiologically Inspired Long-Term Memory for Large Language Models. NeurIPS 37, 2024.

[6] T. H. Haveliwala. Topic-Sensitive PageRank. WWW 2002.

[7] H. Chen, S. F. Sultan, Y. Tian, M. Chen, S. Skiena. Fast and Accurate Network Embeddings via Very Sparse Random Projection. CIKM 2019.

[8] V. D. Blondel, J.-L. Guillaume, R. Lambiotte, E. Lefebvre. Fast Unfolding of Communities in Large Networks. J. Stat. Mech., 2008, P10008.

[9] Yu. A. Malkov, D. A. Yashunin. Efficient and Robust Approximate Nearest Neighbor Search Using Hierarchical Navigable Small World Graphs. IEEE TPAMI 42(4):824–836, 2020.

[10] S. Es, J. James, L. Espinosa Anke, S. Schockaert. RAGAs: Automated Evaluation of Retrieval Augmented Generation. EACL 2024 System Demonstrations, pp. 150–158.

[11] L. Zheng et al. Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena. NeurIPS 2023 Datasets and Benchmarks.

[12] A. Panickssery, S. R. Bowman, S. Feng. LLM Evaluators Recognize and Favor Their Own Generations. NeurIPS 37, 2024.

[13] K. Wataoka, T. Takahashi, R. Ri. Self-Preference Bias in LLM-as-a-Judge. arXiv:2410.21819, 2024.